Software Engineering

Lab 5: Static Code Analysis

56. Loan Eligibility and EMI Calculator

Name: Shriya C Rao

SRN: PES2UG24CS496

Sem: 5

Sec: H

BEFORE:

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>python loan_calculator.py
EMI for 5L @ 9% for 5 years: 375000.000000001
Eligible (score 760, income 15000, EMIs 12000): True
Eligible (unknown loan type 'crypto'): True
Max loan for income 40000: 900000.0
Last schedule row: (12, 87.97, 0.0)
Risk band for 950: LOW
Interest saved by prepaying 50000: 62275.065679061576
Saved as: LN-91425648
Applications on file: 1
Upload to bureau skipped (no network)
```

1)pylint report

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>type before\pylint_report.txt
************* Module loan_calculator
loan_calculator.py:79:0: C0325: Unnecessary parens after 'return' keyword (superfluous-parens)
loan_calculator.py:95:0: C0301: Line too long (113/100) (line-too-long)
loan_calculator.py:1:0: C0114: Missing module docstring (missing-module-docstring)
loan_calculator.py:14:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:14:0: C0103: Function name "calculateEMI" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:20:0: C0103: Function name "checkEligibility" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:20:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
loan_calculator.py:20:0: R0913: Too many arguments (6/5) (too-many-arguments)
loan_calculator.py:20:0: R0917: Too many positional arguments (6/5) (too-many-positional-arguments)
loan_calculator.py:28:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
loan_calculator.py:28:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
loan_calculator.py:28:7: R1714: Consider merging these comparisons with 'in' by using 'loan_type in ('home', 'car', 'personal')'. Use a set instead if eleme
nts are hashable. (consider-using-in)
loan_calculator.py:33:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:33:0: C0103: Function name "maxLoanAmount" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:34:4: W0622: Redefining built-in 'sum' (redefined-builtin)
loan_calculator.py:33:40: W0613: Unused argument 'annual_rate' (unused-argument)
loan_calculator.py:36:8: W0612: Unused variable 'month' (unused-variable)
loan_calculator.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:40:0: C0103: Function name "amortisationSchedule" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:50:0: C0103: Function name "applicationId" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:53:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:53:0: C0103: Function name "saveApplication" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:56:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
loan_calculator.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
```

```
loan_calculator.py:61:0: C0103: Function name "loadApplications" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:62:4: W0603: Using the global statement (global-statement)
loan_calculator.py:63:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
loan_calculator.py:67:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:67:0: C0103: Function name "uploadToBureau" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:70:60: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
loan_calculator.py:73:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:73:0: C0103: Function name "notifyApplicant" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:74:4: W1510: 'subprocess.run' used without explicitly defining the value for 'check'. (subprocess-run-check)
loan_calculator.py:76:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:76:0: C0103: Function name "interestSaved" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:81:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:81:0: C0103: Function name "riskBand" doesn't conform to snake_case naming style (invalid-name)
loan_calculator.py:82:4: R1705: Unnecessary "elif" after "return", replace only that "elif" with "if" (no-else-return)
loan_calculator.py:93:0: C0116: Missing function or method docstring (missing-function-docstring)
loan_calculator.py:104:10: W1309: Using an f-string that does not have any interpolated variables (f-string-without-interpolation)
loan_calculator.py:2:0: W0611: Unused import math (unused-import)

--------------------------------------
Your code has been rated at 5.17/10
```

2)bandit report

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>type before\bandit_report.txt
Run started:2026-10-14 06:34:59.901330+00:00

Test results:
>> Issue: [B402:blacklist] A FTP-related module is being imported.  FTP is considered insecure. Use SSH/SFTP/SCP or some other encrypted protocol.
   Severity: High   Confidence: High
   CWE: CWE-319 (https://cwe.mitre.org/data/definitions/319.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b402-import-ftplib
   Location: .\loan_calculator.py:3:0
2       import math
3       import ftplib
4       import marshal

--------------------------------------------------
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess
   Location: .\loan_calculator.py:6:0
5       import random
6       import subprocess
7       from datetime import datetime

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\loan_calculator.py:51:23
50      def applicationId():
51          return "LN-" + str(random.randint(10000000, 99999999))
52

--------------------------------------------------
>> Issue: [B302:blacklist] Deserialization with the marshal module is possibly dangerous.
   Severity: Medium   Confidence: High
   CWE: CWE-502 (https://cwe.mitre.org/data/definitions/502.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b302-marshal
   Location: .\loan_calculator.py:64:19
63          f = open(file, "rb")
64          applications = marshal.loads(f.read())
65          f.close()
```

```
--------------------------------------------------
>> Issue: [B107:hardcoded_password_default] Possible hardcoded password: 'Bureau#2024'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b107_hardcoded_password_default.html
   Location: .\loan_calculator.py:67:0
66
67      def uploadToBureau(report_path, user="loanops", password="Bureau#2024"):
68          ftp = ftplib.FTP(BUREAU_HOST)
69          ftp.login(user, password)
70          ftp.storbinary("STOR " + os.path.basename(report_path), open(report_path, "rb"))
71          ftp.quit()
72

--------------------------------------------------
>> Issue: [B321:blacklist] FTP-related functions are being called. FTP is considered insecure. Use SSH/SFTP/SCP or some other encrypted protocol.
   Severity: High   Confidence: High
   CWE: CWE-319 (https://cwe.mitre.org/data/definitions/319.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b321-ftplib
   Location: .\loan_calculator.py:68:10
67      def uploadToBureau(report_path, user="loanops", password="Bureau#2024"):
68          ftp = ftplib.FTP(BUREAU_HOST)
69          ftp.login(user, password)

--------------------------------------------------
>> Issue: [B607:start_process_with_partial_path] Starting a process with a partial executable path
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b607_start_process_with_partial_path.html
   Location: .\loan_calculator.py:74:4
73      def notifyApplicant(email, status):
74          subprocess.run(["mail", "-s", "Loan " + status, email])
75

--------------------------------------------------
>> Issue: [B603:subprocess_without_shell_equals_true] subprocess call - check for execution of untrusted input.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html
   Location: .\loan_calculator.py:74:4
73      def notifyApplicant(email, status):
74          subprocess.run(["mail", "-s", "Loan " + status, email])
75

--------------------------------------------------
```

```
Code scanned:
        Total lines of code: 91
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 5
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 7
Files skipped (0):
```

3)Flake8 report

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>type before\flake8_report.txt
loan_calculator.py:2:1: F401 'math' imported but unused
loan_calculator.py:14:1: E302 expected 2 blank lines, found 1
loan_calculator.py:20:1: E302 expected 2 blank lines, found 1
loan_calculator.py:20:80: E501 line too long (85 > 79 characters)
loan_calculator.py:33:1: E302 expected 2 blank lines, found 1
loan_calculator.py:40:1: E302 expected 2 blank lines, found 1
loan_calculator.py:50:1: E302 expected 2 blank lines, found 1
loan_calculator.py:53:1: E302 expected 2 blank lines, found 1
loan_calculator.py:55:80: E501 line too long (88 > 79 characters)
loan_calculator.py:61:1: E302 expected 2 blank lines, found 1
loan_calculator.py:67:1: E302 expected 2 blank lines, found 1
loan_calculator.py:70:80: E501 line too long (84 > 79 characters)
loan_calculator.py:73:1: E302 expected 2 blank lines, found 1
loan_calculator.py:76:1: E302 expected 2 blank lines, found 1
loan_calculator.py:78:80: E501 line too long (83 > 79 characters)
loan_calculator.py:81:1: E302 expected 2 blank lines, found 1
loan_calculator.py:93:1: E302 expected 2 blank lines, found 1
loan_calculator.py:95:80: E501 line too long (113 > 79 characters)
loan_calculator.py:96:80: E501 line too long (98 > 79 characters)
loan_calculator.py:100:80: E501 line too long (86 > 79 characters)
loan_calculator.py:104:11: F541 f-string is missing placeholders
loan_calculator.py:106:1: E305 expected 2 blank lines after class or function definition, found 1
```

AFTER:

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>python loan_calculator.py
EMI for 5L @ 9% for 5 years: 375000.000000001
Eligible (score 760, income 15000, EMIs 12000): True
Eligible (unknown loan type 'crypto'): True
Max loan for income 40000: 900000.0
Last schedule row: (12, 87.97, 0.0)
Risk band for 950: LOW
Interest saved by prepaying 50000: 62275.065679061576
Saved as: LN-77550076
Applications on file: 1
Upload to bureau skipped (no network)
```

1)pylint report

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>type after\pylint_report.txt
************* Module loan_calculator
loan_calculator.py:86:4: W0603: Using the global statement (global-statement)

-----------------------------------------------------------------
Your code has been rated at 9.89/10 (previous run: 9.89/10, +0.00)
```

2)bandit report

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>type after\bandit_report.txt
Run started:2026-10-14 16:28:52.770141+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 140
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 1

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

3)Flake8 report

```
(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>type after\flake8_report.txt

(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>flake8 loan_calculator.py

(venv) C:\Users\Shriya C Rao\L5_57_loan-eligibility>echo Flake8 completed with exit code %ERRORLEVEL%
Flake8 completed with exit code 0
```

Issues table:

Issue	**Type**	**Line(s)**	**Description**	**Fix Approach**
FTP usage	Security - High	3, 68	FTP was used for uploading reports, which is an insecure protocol.	Removed FTP and replaced the upload mechanism with HTTPS.
Unsafe deserialization	Security - Medium	64	marshal.loads() was used to deserialize stored application data.	Replaced marshal with JSON for storing and loading applications.
Hardcoded password	Security - Low	67	A bureau password was directly written in the source code.	Removed the hardcoded password and used the BUREAU_TOKEN environment variable.

Insecure random generation	Security - Low	51	random.randint() was used to generate application IDs.	Replaced it with the secrets module.
Subprocess execution	Security - Low	74	subprocess.run() was used to launch a mail command.	Removed the subprocess call and changed the function to record a notification message.
Missing docstrings	Code Quality	Multiple	The module and several functions did not have proper documentation.	Added module and function docstrings.
Function naming convention	Code Quality	Multiple	Several function names did not follow the recommended snake_case convention.	Renamed functions to follow the naming convention.
Mutable default argument	Code Quality	20	A mutable list was used as a default function argument.	Removed the mutable default argument.
Unused import	Code Quality	2	The math module was imported but was not used.	Removed the unused import.
Long lines and formatting	Style	Multiple	Several lines exceeded the allowed length and required formatting was missing.	Reformatted long lines and added proper spacing.